

****Warsaw, March 12, 2024****

****Decision****

DKN.5131.28.2023

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), Article 7(1) and Articles 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57(1)(a) and (h), Article 58(2)(i), Article 83(1) and (2), Article 83(4)(a) in connection with Article 33(1) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by Toyota Bank Polska S.A. with its registered office in Warsaw (ul. Postępu 18B, 02-676 Warsaw), the President of the Personal Data Protection Office, finding that Toyota Bank Polska S.A. with its registered office in Warsaw (ul. Postępu 18B, 02-676 Warsaw) violated Article 33(1) of Regulation 2016/679 by failing to notify the President of the Personal Data Protection Office of the personal data breach without undue delay and no later than 72 hours after becoming aware of the breach,

imposes on Toyota Bank Polska S.A. with its registered office in Warsaw (ul. Postępu 18B, 02-676 Warsaw) an administrative fine of 78,575.40 PLN (in words: seventy-eight thousand five hundred seventy-five zlotys and forty groszy).

****Justification****

On September 7, 2022, Toyota Bank Polska S.A. with its registered office in Warsaw (ul. Postępu 18B, 02-676 Warsaw), hereinafter referred to as the "Bank" or "Administrator", reported to the President of the Personal Data Protection Office, hereinafter also referred to as the "President of UODO" or "supervisory authority", a personal data breach involving the personal data of one natural person (hereinafter "Data Subject" or "Bank Client") concerning: first name and surname, bank account number, residential address, PESEL identification number, series and number of the identity card. The personal data breach consisted of sending—due to an employee's error—a bank shipment containing a contract and repayment schedule for a loan to another Bank client. The shipment was received and opened by that client, resulting in the disclosure of the Bank Client's personal data to an unauthorized person. After the Bank sent a courier to the person in possession of the incorrectly sent shipment, the correspondence was returned to the Bank. The explanations provided indicate that the Bank registered a security incident in connection with the situation; however, it did not notify the supervisory authority of the personal data breach within 72 hours of its discovery.

In the notification form regarding the personal data breach, the Administrator indicated March 31, 2021, as the date of the breach, while the notification was made only on September 7, 2022, justifying the reasons for the delay in notifying the supervisory authority of the personal data breach by stating that "the Bank assessed the risk of infringement of the rights and freedoms of the data subjects as low; however, after the occurrence of UODO, it changed the rules for conducting assessments." The occurrence referred to in the Bank's explanations concerns proceedings conducted by the President of UODO regarding a complaint from the Bank Client related to the aforementioned personal data breach, concerning irregularities in the processing of her personal data by Toyota Bank Polska S.A., consisting of disclosing personal data to a third party without legal basis (case no. (...)).

Due to the notification of the personal data breach to the supervisory authority after the expiration of the 72-hour period from its discovery, i.e., nearly 1.5 years after its discovery, the President of UODO initiated ex officio administrative proceedings against the Bank regarding the violation of Article 33(1) of Regulation 2016/679.

In response to the notification of the initiation of administrative proceedings in this matter, in a letter

dated October 19, 2023, the Bank submitted additional explanations, indicating that "Assessing the seriousness of the breach in question, the Bank took into account the following circumstances: (i) the breach concerned only one person, (ii) the document containing the data was quickly recovered, (iii) there were no reasons to assume bad faith on the part of the person who gained unauthorized access to the data as a result of the breach, particularly given that this person was a Bank client, informed the Bank of the incident, and cooperated with the Bank to return the incorrectly addressed shipment, and (iv) the fact that the Bank knew this person's personal data, which in the Bank's opinion constituted a circumstance reducing the risk of unauthorized use of this data to the detriment of the person whose data was breached. Furthermore, during the assessment, a significant reference point was the ENISA guidelines on assessing the seriousness of the breach, which indicated that the above-mentioned circumstances reduce the seriousness of the breach and suggested that breaches for which the risk of negative consequences is low should not be subject to notification to the supervisory authority. consequences for the rights and freedoms of individuals is "minimal."

The reason for not reporting the personal data breach to the President of the Personal Data Protection Office (UODO), according to the Bank, was "[...] a thorough assessment of the severity of the breach, within the interpretation of Article 33(1) of the GDPR, based on market practice and available guidelines from the agency competent in information security (ENISA)." Furthermore, as soon as the Bank "became aware of the expectations of the President of the UODO regarding the application of Article 33(1) of the GDPR" - "it immediately took action to align its practices in this regard with the expectations of the President of the UODO. The result of the Bank's change in approach was to inform the President of the UODO about the breach that underlies this proceeding."

In the further part of its explanations, the Bank indicates that regardless of the assessment of the personal data breach in the context of Article 33(1) of Regulation 2016/679, it proactively informed the individual affected by the breach, thus "although it did not report the breach immediately after its occurrence due to the risk assessment applied, it nevertheless fulfilled the primary obligation imposed on the data controller, namely, it countered the effects of the breach by promptly informing in writing the individual whose data was affected."

In the Bank's opinion, the delay in reporting the breach to the President of the UODO did not negatively impact the rights and freedoms of the individual whose data was involved. The client had the opportunity to counteract the effects of the personal data breach immediately after its occurrence; moreover, she received support from the Bank, which, among other things, covered the costs of purchasing a code (...).

On January 23, 2024, a letter from the Administrator was received, which constituted a reiteration of the previously submitted explanations by the Bank, thereby emphasizing the Bank's existing position in this matter.

After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office noted the following:

According to Article 4(12) of Regulation 2016/679, "a personal data breach" means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

Article 33(1) and (3) of Regulation 2016/679 states that in the event of a personal data breach, the controller shall without undue delay – where feasible, not later than 72 hours after becoming aware of the breach – notify the supervisory authority competent under Article 55, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons. Any notification submitted to the supervisory authority after the 72-hour period must include an explanation of the reasons for the delay. The notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, and the categories and approximate number of personal data records concerned; b) include the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d)

describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

From the analysis of the above provisions, it follows that depending on the level of risk to the rights or freedoms of natural persons that the controller is dealing with, its obligations towards the supervisory authority and the individuals concerned are shaped differently. If, as a result of the analysis, the controller determines that the likelihood of a risk to the rights or freedoms of natural persons is low, it is not obliged to notify the President of the Personal Data Protection Office of the breach. The indicated breach must only be recorded in the internal breach register. In the case of identifying a risk to the rights or freedoms of natural persons, the controller is obliged to notify the personal data breach to the President of the UODO, as well as to make an entry in the internal breach register. The occurrence of a high risk to the rights or freedoms of natural persons, in addition to the entry in the breach register, requires the controller to take appropriate actions, both towards the supervisory authority (notification of the personal data breach) and also towards the individuals concerned.

In the case of personal data breaches that may result in a high risk to the rights or freedoms of the data subject, Regulation 2016/679 introduces an additional obligation for the controller to promptly notify the data subject, unless the controller has taken preventive measures before the breach occurred or remedial actions after the breach occurred (Article 34(3) of Regulation 2016/679).

As follows from the above, in the event of the controller detecting a personal data breach, it is first necessary to conduct an analysis regarding the occurrence of a risk to the rights or freedoms of natural persons. The controller is exempt from the obligation to notify the supervisory authority of the breach if, as a result of the conducted assessment, it turns out that there is at most a low probability of the occurrence of a risk to the rights or freedoms of natural persons. However, it should be borne in mind that the supervisory authority may request the controller to justify its decision.

not only lead to significant risks for that individual but also undermine the overall trust in the data processing practices of the organization involved. The obligation to report personal data breaches is thus not merely a regulatory requirement but a fundamental aspect of responsible data management that protects the rights and freedoms of individuals.

1. ****Non-reporting of Breaches****

In connection with this, the findings from the conducted analysis should be recorded in the internal register of breaches. It is worth recalling that in the Guidelines of the European Data Protection Board (EDPB) No. 9/2022[1] adopted on March 28, 2023, there are recommendations regarding the reporting of personal data breaches to the supervisory authority. It should be emphasized that the risk assessment of a breach of the rights or freedoms of a natural person should be made from the perspective of the data subject, not the interests of the data controller. The failure to report a personal data breach deprives the supervisory authority of the ability to respond appropriately to the breach, which is manifested not only in the assessment of the risk of the breach to the rights or freedoms of the individual but also, in particular, in verifying whether the controller has taken appropriate measures to remedy the breach and minimize the negative effects for the individuals concerned, as well as whether appropriate security measures have been implemented to minimize the risk of a recurrence of the breach.

2. ****Importance of Reporting****

Reporting personal data breaches by controllers is therefore an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, controllers inform the President of the Personal Data Protection Office (UODO) whether they believe there is a high risk of infringement of the rights or freedoms of the individuals concerned and, if such a risk exists, whether they have provided relevant information to the individuals affected by the breach. The President of UODO verifies the assessment made by the controller and may, if the controller has not notified the individuals concerned, demand such notification. Reporting personal data breaches allows the supervisory authority to respond appropriately, which can mitigate the consequences of such breaches, as the controller is obliged to take effective actions to ensure the protection of individuals and their personal data, which on one hand allows for the control of the

effectiveness of existing solutions, and on the other hand, the assessment of modifications and improvements aimed at preventing irregularities similar to those covered by the breach. Furthermore, notifying individuals about the breach provides an opportunity to convey information about the risks associated with the breach and to indicate actions that those individuals can take to protect themselves from potential negative consequences of the breach (this enables the individual to make an independent assessment of the breach in the context of the possibility of materializing negative consequences for that individual and to decide whether to take or refrain from taking remedial actions).

3. ****Administrator's Statement****

In a letter dated October 19, 2023, the Administrator states that "In the opinion of the Bank, the delay in reporting the breach to UODO did not negatively affect the rights and freedoms of the individual concerned, as the client had the opportunity to counteract the effects of the breach immediately after its occurrence; moreover, she received support from the Bank in this regard, which, among other things, covered the costs of purchasing a code (...) (which is also currently a standard of the Bank)." In the opinion of the supervisory authority, the fact that the individual concerned by the breach of personal data filed a complaint with the President of UODO regarding irregularities in the processing of her personal data by the Bank, consisting of disclosing her personal data to a third party without legal basis, indicates that the Bank's response to this breach was insufficient, and the Client herself had concerns about the security of the data processed by the Bank.

4. ****Scope of Data Processing****

Toyota Bank Polska S.A., due to the scale and nature of its activities, i.e., providing various types of financial services, processes the personal data of a very large number of clients with whom it enters into, among other things, credit agreements. In the case under consideration, unauthorized access was gained to the personal data of the Bank's Client contained in the agreement between the parties, i.e., the PESEL number, first and last name, residential address, bank account number, and series and number of the identity card. There is no doubt that based on the disclosed data, the Data Subject can be easily identified. Furthermore, data related to the conclusion of the agreement and its content were disclosed. Consequently, the assessment of the breach conducted by the Administrator in terms of the risk of infringement of the rights or freedoms of individuals, necessary to determine whether there was a breach of data protection resulting in the obligation to notify the President of UODO (Article 33(1) and (3) of Regulation 2016/679) and the individuals concerned by the breach (Article 34(1) and (2) of Regulation 2016/679), should, as it should be emphasized once again, be made from the perspective of the individual affected by the breach.

5. ****Notification Obligations****

Although the Bank informed the individual concerned about the personal data breach by providing her with the content of the notification, due to the failure to make the appropriate report of the personal data breach to the President of UODO within the time limits prescribed by law (72 hours from the discovery of the breach), it deprived the supervisory authority of the opportunity to take appropriate action in response to this breach, and consequently, the ability to conduct a proper analysis of the content of the notification directed to that individual, in terms of the fulfillment by the Administrator of the obligations arising from Article 34(2) in connection with Article 33(3) of Regulation 2016/679 and providing the Data Subject with complete information regarding the possible consequences of the breach, as well as the measures that the individual can take to protect herself from potential consequences of the breach.

6. ****Conclusion****

It should be remembered that the accidental disclosure of personal data to even one identified individual can lead to significant risks for that individual and undermine the overall trust in the data processing practices of the organization involved.

the unauthorized recipient would misuse the personal data of the Bank's Client. The assessment of the risk conducted by the Bank appears to overlook the fundamental principle of data protection, which emphasizes the need for caution and the safeguarding of personal data, regardless of the relationship between the parties involved.

In summary, the Bank's rationale for not reporting the data breach lacks sufficient justification and fails to adequately address the potential risks associated with the unauthorized disclosure of personal data. The mere fact that the unauthorized recipient was a client of the Bank does not eliminate the risk of harm to the rights and freedoms of the data subject. The Bank must ensure that it adheres to the principles of accountability and transparency in its handling of personal data breaches, and it is imperative that it takes all necessary steps to mitigate any potential risks to individuals whose data may have been compromised.

Violation resulted in the risk of infringement of the rights or freedoms of natural persons and does not exclude the acceptance that there was a high risk of infringement of the rights or freedoms of the data subject. It should be reiterated that personal data was disclosed to an unauthorized recipient, which means that a security breach occurred leading to the unauthorized disclosure of personal data; the unauthorized recipient cannot be considered a "trusted recipient," and the scope of this data determines that there was a high risk of infringement of the rights or freedoms of the natural person. Furthermore, the Bank's Client, to whom the incident in question pertains, filed a complaint with the President of the UODO regarding irregularities in the processing of her personal data by the Bank, consisting of disclosing her personal data to a third party without legal basis. The Data Subject's filing of a complaint, in the opinion of the President of the UODO, confirms that the risk assessment presented in the Bank's explanations in this matter does not take into account the perspective of the Bank's Client, who, as a result of the breach of her personal data protection, most likely suffered non-material damage. As indicated in Guidelines 9/2022, a breach of personal data protection can potentially lead to a number of negative consequences for the natural persons whose data is the subject of the breach. Among the possible consequences of the breach, the EROD mentions: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of confidentiality of personal data, and significant economic or social harm. In this case, there is no doubt that due to the scope of the data covered by the breach of personal data protection, including the PESEL identification number along with the first and last name, there is a high probability of the occurrence of the aforementioned damages.

First and foremost, it should be emphasized that the breach of personal data protection concerned the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing, among other things: date of birth and gender designation, and thus is closely related to the private sphere of the natural person and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679 – being data of a special nature and requiring such special protection. The PESEL number serves as identifying data for each person and is commonly used in dealings with various institutions and in legal circulation. The PESEL number along with the first and last name unequivocally identifies a natural person, in a way that allows for attributing negative consequences of the breach (e.g., identity theft, loan fraud) to that specific person. Furthermore, it should be taken into account that as a result of the breach of personal data protection, the PESEL identification number was disclosed to an unauthorized person along with the first and last name of the Bank's Client, which combination of data may be sufficient to "impersonate" the data subject and incur obligations in the name of and to the detriment of such a subject, e.g., financial obligations (see:

<https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> – where a case is described in which: "Only the first name, last name, and PESEL number were enough for fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the address of residence"). It is also impossible to overlook that the analyzed breach of personal data protection also concerned the address of residence, bank account number, and series and number of the Bank's Client's ID card. In risk assessment, the key factor is the type and sensitivity of the personal data disclosed as a result of the breach. In Guidelines 9/2022, it was emphasized that a collection of various personal data usually has a more sensitive nature than individual data.

Furthermore, as indicated by the case law, judgments in cases of credit fraud are not uncommon and have been issued by Polish courts in similar matters for a long time – for confirmation, one can

mention, for instance, the judgment of the District Court in Łęczyca dated July 27, 2016 (case file no. I C 566/15), in which fraudsters taking a loan using someone else's data used a PESEL number, a fictitious address, and an incorrect identification number (invalid). In the justification of the aforementioned judgment, the Court stated that: "The conducted evidentiary proceedings and the analysis of documents submitted by the plaintiff result in a clear conclusion that in the case under consideration, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used during its conclusion, the indicated place of residence does not correspond to the place of residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of concluding the loan agreement, the identity card no. (...) lost its validity on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant."

In another case (I C 693/16), the District Court in Zgierz ruled in a judgment dated November 4, 2016: "The personal data of the defendant in the form of his name and surname and PESEL number, which were consistent with the data of the defendant, did not indicate that the defendant submitted a declaration of will to conclude a loan agreement on December 17, 2014. It is possible that a person who unlawfully gained access to the personal data of the defendant concluded a loan agreement on his behalf with the company (...) sp. z o.o. S.K.A. based in W. In this case, the defendant demonstrated that he never lived at the address indicated in the loan agreement and that the phone number and email address used to register on the website and submit the loan application belonged to him."

Similarly, courts have ruled in other such cases. As an example, one can cite judgments in which the courts dismissed claims for payment of amounts for loans taken out by unknown persons using the personal data (name and surname and PESEL number) of the defendants: Judgment of the District Court for Łódź-Widzew in Łódź dated August 13, 2020, in case file no. II C 1145/19, in which an unknown third party unlawfully obtained the defendant's PESEL number and identification number, while the remaining address data indicated in the loan agreement was false – "In the Court's opinion, the evidence offered by the defendant – especially the documents from the criminal case pending before the District Court in Tarnowskie Góry under case file no. VI K 383/16 – indicates that the loan agreement dated November 8, 2014, was concluded by a third party using some personal data of Z. A. They provided a false address of residence, under which the defendant never lived, and the loan amount was transferred to a bank account that did not belong to Z. A. [...] and the identification number provided in this agreement was a number that the defendant no longer used at the time of concluding the loan agreement, as this document had lost its validity about 8 months earlier";

Judgment of the District Court in Pisz dated August 21, 2020, case file no. I C 260/20 – "[...] The Court found that when concluding the subject agreement, the defendant's data was unlawfully used and entered as the borrower's data, while it was not the defendant who was a party to the agreement. The defendant's position is confirmed by the notification he submitted regarding the commission of fraud to his detriment, as well as by the fact that the prosecutor's office is conducting proceedings in this matter against the person indicated by the defendant. It should be noted that also in the ongoing proceedings before this court for payment under case files I C 1/19 and I C 482/19, where E. M. also appeared as the defendant, and where financial obligations were incurred in his name and surname under the same circumstances as in this proceeding, final judgments dismissing the claims were also issued. In the Court's opinion, the circumstances of concluding the agreement with the plaintiff, where the first name and surname of the borrower and his PESEL number are identical, while there is a discrepancy regarding the remaining data resulting from the content of the defendant's identity card, i.e., the series and number of this document, the address of residence, taking into account the fact of conducting criminal proceedings against the person who allegedly impersonated the defendant to conclude agreements remotely and incur financial obligations in various institutions, clearly indicate that it was not the defendant who concluded the loan agreement no. (...) with the plaintiff's legal predecessor";

Judgment of the District Court in Puławy dated April 7, 2022, in case file no. I C 475/19, in which the Court unequivocally stated that "[...] the evidence allowing for the verification of the defendant as a

party to the subject agreement is not constituted solely by the indication of his personal data: name, surname, PESEL number, as well as the series and number of the identity card in the content of the agreement – especially in a situation where the loan is concluded via an online platform, and thus, it is obvious that the lender does not have the possibility of directly verifying the identity of the other party, and the agreement itself is not confirmed by the borrower's signature.”

“It is also significant that, as indicated by the delivery card of the shipment with the debit card, the identity card no. (...) presented to the deliverer had a validity date until September 21, 2019, while the original identity card belonging to Ł. B. (1) was valid until June 2, 2021 (k. 220), which confirms... the defendant's testimony, also regarding the fact that a probable source of the "leak" of his personal data was the car sale agreement he entered into on June 8, 2017, which, in addition to the seller's name and surname and his PESEL number, also includes the ID card number. However, this agreement does not contain data regarding the names of the parents - and in the bank account agreement, this data is already incorrectly entered, as well as the expiration date of the ID card - which is also incorrectly entered in the delivery card of the bank account agreement, which clearly indicates that the person entering into the bank account agreement did not have any data of Ł. B. (1) other than those contained in the car sale agreement, as well as the original ID card - which, as indicated by the defendant's testimony, is still in his possession and has not been made available to third parties.

It is worth citing one of the examples found in the Guidelines of the European Data Protection Board 01/2021[2] (case no. 14, p. 31), relating to the situation of "sending highly confidential personal data by mail by mistake." In the case described in the aforementioned Guidelines, there was a disclosure of a social security number, which is equivalent to the PESEL number used in Poland. In this case, the EDPB had no doubt that the disclosed data regarding: name and surname, email address, postal address, and social security number indicate a high risk of infringement of the rights or freedoms of natural persons ("the involvement of their [the affected persons] social security number, as well as other, more basic personal data, further increases the risk that can be described as high"). The EDPB recognizes the importance of national identification numbers (in this case, the PESEL number), while emphasizing that this type of personal data breach, therefore encompassing data in the form of: name and surname, email address, postal address, and social security number, requires the implementation of actions, i.e.: notifying the supervisory authority and informing the affected individuals about the breach.

The European Data Protection Board has no doubt that an individually assigned number that unequivocally identifies a natural person should be subject to special protection, and its disclosure to unauthorized entities may be associated with a high risk of infringement of the rights or freedoms of natural persons.

The fact that data unequivocally identifying a natural person may pose a high risk of infringement of rights or freedoms is also indicated by the EDPB in other examples provided in the Guidelines 01/2021. In points 65 and 66 of the Guidelines 01/2021, it is stated: "(...) The breached data allow for the unequivocal identification of the individuals to whom the data pertains and contain other information about them (including gender, date and place of birth); moreover, they can be used by an attacker to guess customer passwords or to conduct a spear-phishing campaign targeting bank customers. For these reasons, it was concluded that the data breach is likely to cause a high risk of infringement of the rights and freedoms of all individuals whose data is concerned. Consequently, there may be material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud)."

Similar doubts (that the disclosure of the PESEL number along with other personal data may cause a high risk of infringement of the rights or freedoms of natural persons) were also held by the Provincial Administrative Court in Warsaw, which in its judgment of September 22, 2021, case no. II SA/Wa 791/21, stated that "There is no doubt that the examples of harm cited in the guidelines may occur in the case of individuals whose personal data – in some cases including the PESEL identification number or the series and number of the ID card – have been recorded on shared recordings. The possibility of identifying individuals whose data has been breached based on the disclosed data is

significant for such an assessment.” Furthermore, the Court in the aforementioned ruling indicated that “The data was disclosed to unauthorized persons, which means that a security breach occurred leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the ID card, determines that there is a high risk of infringement of the rights or freedoms of natural persons.”

Considering the above issues, it is also necessary to refer to the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, in case no. II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: “It should be agreed with the President of the UODO that the loss of confidentiality of the PESEL number in conjunction with personal data such as: name and surname, registered address, bank account numbers, and the identification number assigned to Bank customers - the CIF number, is associated with a high risk of infringement of the rights or freedoms of natural persons. In the event of a breach of such data as name, surname, and PESEL number, identity theft or forgery may occur, resulting in negative consequences for the individuals whose data is concerned. Therefore, the Bank in this matter should have promptly, in accordance with Article 34(1) of the GDPR, notified the individuals whose data is concerned about the breach of personal data protection, so as to enable them to take necessary preventive actions.” It should also be noted the judgment of August 31, 2022, case no. II SA/Wa 2993/21, in which the Provincial Administrative Court in Warsaw emphasized that “(...) the authority rightly concluded that there was a high risk of infringement of the rights and freedoms of individuals affected by the breach due to the possibility of easy identification based on the disclosed data.” the data breach. These data include the first name and surname, correspondence address, telephone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals concerned about the breach.” Similarly, the Provincial Administrative Court in Warsaw expressed itself in judgments dated November 15, 2022, case file II SA/Wa 546/22, June 21, 2023, case file II SA/Wa 150/23, and November 6, 2023, case file II SA/Wa 996/23. In light of the above, it is also worth recalling the judgment of the Supreme Administrative Court in Warsaw dated December 6, 2023, case file III OSK 2931/21: “The President of the UODO correctly established that there was a disclosure of data, including first names and surnames, as well as PESEL numbers of natural persons, and thus relatively permanent, unchanging data, the disclosure of which may always pose a risk of negative consequences for the aforementioned individuals. Similarly, residential addresses are personal data, the unauthorized disclosure of which creates a high probability of negative legal consequences, regardless of the fact that the disclosure of addresses occurred several years after their last update.”

It should also be noted that the Administrator's fulfillment of its obligation arising from Article 33(1) of Regulation 2016/679 cannot be conditioned on the occurrence of a violation of the rights or freedoms of the natural persons whose data is subject to the breach of personal data protection. As stated by the Provincial Administrative Court in Warsaw in the judgment dated September 22, 2021, in case file II SA/Wa 791/21: “It should be emphasized that the possible consequences of the event do not have to materialize. The content of Article 33(1) of Regulation 2016/679 indicates that the mere occurrence of a breach of personal data protection, which is associated with a risk of violation of the rights or freedoms of natural persons, implies the obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach would result in a risk of violation of the rights or freedoms of natural persons” (and this Court similarly ruled in the previously cited judgment dated July 1, 2022, in case file II SA/Wa 4143/21, as well as in judgments dated August 31, 2022, case file II SA/Wa 2993/21, November 15, 2022, case file II SA/Wa 546/22, and April 26, 2023, case file II SA/Wa 1272/22).

In the letter dated October 19, 2023, the Administrator states: “The assessment made by the Bank, indicating the lack of an obligation to notify the breach, also stemmed from the lack of a clear practice of the President of the UODO regarding the reporting of personal data breaches at the time of assessing the breach, i.e., in April 2021. In 2021, the practice of applying Article 33(1) was just being shaped, as evidenced by many publicly available and widely commented decisions of the President of

the UODO issued at the turn of 2021 and 2022, which ultimately shaped this practice (including (...) from October 14, 2021, (...) from July 7, 2022, (...) from June 21, 2021)."

It is impossible to agree with the above argumentation of the Bank, as the President of the UODO, and previously the General Inspector for Personal Data Protection, has consistently maintained for many years that the PESEL number is a unique identifier of a person, containing many pieces of information, including age and gender, and its disclosure to an unauthorized person may pose a risk of identity theft. The decisions issued in this regard only confirm the above.

Particular protection of personal data, including primarily the PESEL identification number, is also required from public trust institutions, which undoubtedly includes the party to the subject proceedings. Considering the previous activities of the President of the UODO, who takes possible, appropriate steps aimed at protecting the national identification number – PESEL, such as even regarding the disclosure of the PESEL number in the National Court Register or in qualified electronic signatures, it clearly indicates how – according to the supervisory authority – one should act in the event of a possible disclosure of the PESEL number. The President of the UODO has repeatedly pointed out that processing the PESEL number without adhering to appropriate security principles poses a number of threats to the privacy of the individual, and its disclosure in many places facilitates identity theft, as well as profiling a person without their knowledge and consent.

Above all, however, during the period in which the breach occurred, similar cases of breaches were reported to the supervisory authority, as confirmed by the report on the activities of the President of the Office for Personal Data Protection published this year on the UODO website, and breaches involving the loss of correspondence by the postal operator or opening correspondence before returning it to the sender were among the most frequently reported breaches of personal data protection by data administrators.

Therefore, the explanations provided by the Bank are incomprehensible, as it attributes the lack of notification of the personal data breach to the ambiguous practice of the President of the UODO in this area, while simultaneously failing to utilize the materials and necessary guidance provided by the President of the UODO. Importantly, by deciding not to report the personal data breach to the supervisory authority, the Administrator deprived itself of the opportunity to verify the correctness of its own practice.

On one hand, the Bank claims that "The statement of the President of the UODO, which indicates that notification under the procedure provided for in Article 33(1) of the GDPR ((...)) applies to any breach involving, among others, the PESEL number is dated July 1, 2021, and thus already after the occurrence of the breach in question."

****Proceedings****, in further explanations, indicates that: "From the moment the Bank became aware of the expectations of the President of the UODO regarding the application of Article 33(1) of the GDPR, the Bank immediately took action to adapt its own practices in this regard to the expectations of the President of the UODO. As a result of the change in the Bank's approach, the President of the UODO was informed about the breach that underlies these proceedings."

Regarding the first statement, in matters analogous to this one, to which the subject proceedings pertain, the President of the UODO also informed the Bank in letters prior to July 1, 2021, such as in the case with reference number (...), where the request was sent on March 26, 2021, thus during the period when the breach occurred that is the subject of these proceedings. As for the second statement – the notification of the personal data breach, the Bank did not act following the initial requests sent in cases of notifications of personal data breaches, where, in the opinion of the supervisory authority, a proper risk analysis regarding the rights or freedoms of the natural persons concerned was not conducted, but only as a result of the summons sent on September 1, 2022, to supplement the explanations regarding the complaint filed by the person to whom the breach pertains (reference number (...)), in which letter the supervisory authority asked the Bank to indicate whether it had made a notification of the personal data breach to the supervisory authority in accordance with the provisions of Article 33 of Regulation 2016/679.

It is worth noting that, for example, the notification of the personal data breach dated February 12, 2021, with reference number (...), which also involved sending correspondence to the wrong recipient, and in which the scope of personal data was almost identical to the breach that is the subject of these proceedings (the only difference concerned the series and number of the identity document – in the notification (...), the data disclosed included: first name and surname, PESEL identification number, bank account number, residence or stay address, contract number), was reported by Toyota Bank Polska S.A. to the supervisory authority.

In the case of the personal data breach, the failure to notify the supervisory authority within 72 hours of its discovery led to the initiation of these proceedings. The Bank notified the person concerned about the breach of their personal data, anticipating that this breach could pose a high risk to the rights and freedoms of natural persons – thus, it was even more obliged to notify the supervisory authority of this breach. As follows from Article 33(1) of Regulation 2016/679, in the case of a personal data breach, the controller shall notify the supervisory authority without undue delay, unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons.

In the context of the aforementioned explanations, the Bank seems to forget that when applying the provisions of Regulation 2016/679, the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of natural persons, particularly their right to the protection of personal data, must be taken into account. Moreover, the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the event of any doubts, for example, regarding the fulfillment of obligations by controllers – including in situations where a personal data breach has occurred – these values should be considered first.

Obtaining by the supervisory authority the full information required under Article 33(3) of Regulation 2016/679 about a specific personal data breach allows it to properly assess such a breach and respond appropriately, for example, by demanding that the controller notify the data subjects when necessary, and the controller has not done so on its own initiative. A lack of appropriate and prompt response to personal data breaches increases the risk of associated damages materializing.

It is important to emphasize that when assessing the risk of infringement of the rights or freedoms of natural persons, which is among the factors determining the obligation to notify a personal data breach, both the likelihood and the severity of potential negative consequences must be taken into account collectively. A high level of either of these factors affects the overall assessment, which determines the fulfillment of the obligation specified in Article 33(1) of Regulation 2016/679.

Considering that due to the scope of the disclosed personal data in the analyzed case, there was a possibility of serious negative consequences for the person whose data is concerned (as demonstrated above), the weight of the potential impact on the rights or freedoms of the natural person should be considered high. At the same time, the likelihood of high risk arising from the breach in question is not small and has not been eliminated. Therefore, it should be stated that in connection with the breach in question, there was a high risk of infringement of the rights or freedoms of the person whose data is concerned, which consequently determines the obligation to notify the supervisory authority of the personal data breach.

In Guidelines 9/2022, the EROD indicates the factors to be considered when assessing risk, referring to Recitals 75 and 76 of Regulation 2016/679, which suggest that the controller should take into account both the likelihood of occurrence and the severity of the threat to the rights or freedoms of the data subject. In the case of a personal data breach, the controller should focus on the risk of impact on the individual resulting from the breach. Thus, when assessing the risk...

for a natural person resulting from a breach of personal data protection, the administrator should take into account the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence. In this regard, when assessing the risk, the EROD recommends considering criteria such as: the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, as these may affect the level of risk to individuals. The risk of infringement of the rights and freedoms of a natural person, according to Guidelines 9/2022, will be

greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. The guidelines indicate that, in case of any doubts, the administrator should report the breach, even if such caution may seem excessive.

In summary, it should be stated that in the present case there is a high risk of infringement of the rights or freedoms of the person affected by the breach, which in turn resulted in the Bank's obligation to report the breach of personal data protection to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679, as well as – which has been done – notifying that person about the breach, in accordance with Article 34(1) of Regulation 2016/679, which must include the information specified in Article 34(2) of Regulation 2016/679. It should also be stated that in the present situation there are no grounds to conclude that the Administrator was exempt from the obligation to report the breach of personal data protection to the supervisory authority in accordance with Article 33(1) of Regulation 2016/679 and from the obligation to notify the person whose data is affected by this breach (in accordance with Article 34(1) of this regulation). In the circumstances of the examined case, it cannot be reasonably argued that it is unlikely that this breach would result in a risk of infringement of the rights or freedoms of the Data Subject. This breach concerned data including: name and surname, PESEL identification number, residential address, bank account number, series and number of the identity card of the aforementioned person contained in the agreement along with the repayment schedule of the loan, which was disclosed to an unauthorized person. In the opinion of the supervisory authority, there is therefore no justification for the Bank's failure to fulfill the obligation arising from Article 33(1) of Regulation 2016/679, the violation of which is the subject of this proceeding.

In Recital 85 of the preamble to Regulation 2016/679, it is explained: "In the absence of an appropriate and timely response, a breach of personal data protection may result in physical harm, material or non-material damage to individuals, such as loss of control over their personal data or restriction of rights, discrimination, identity theft or fraud, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, or any other significant economic or social damage. Therefore, immediately after identifying a breach of personal data protection, the administrator should report it to the supervisory authority without undue delay, if feasible, no later than 72 hours after the breach is identified, unless the administrator can demonstrate in accordance with the principle of accountability that it is unlikely that the breach could result in a risk to the rights or freedoms of individuals. If it is not possible to report within 72 hours, the report should be accompanied by an explanation of the reasons for the delay, and information may be provided gradually, without further undue delay."

In summary of the above argumentation of the supervisory authority, it should be stated that the Administrator – despite updating himself on the obligations in the circumstances of the analyzed case – did not report the breach of personal data protection to the supervisory authority within 72 hours of identifying the breach, which means that the Bank violated the obligation under Article 33(1) of Regulation 2016/679.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of the UODO states that in the case at hand, there are grounds justifying the imposition of an administrative fine on the Bank based on Article 83(4)(a) of Regulation 2016/679, which states, among other things, that a breach of the obligations of the administrator referred to in Article 33 of Regulation 2016/679 is subject to an administrative fine of up to 10,000,000 EURO, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Pursuant to Article 83(2) of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a) - (h) and (j) of Regulation 2016/679. In deciding to impose an administrative fine on the Bank, the President of the UODO – in accordance with Article 83(2)(a) - (k) of Regulation 2016/679 – took

into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which weigh heavily on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the breach.

considering the nature, scope, or purpose of the given processing, the number of affected individuals whose data is concerned, and the extent of the damage incurred by them (Article 83(2)(a) of Regulation 2016/679). In this case, a violation of Article 33(1) of Regulation 2016/679 was found (consisting of the failure to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach). This is related to an event involving the disclosure to an unauthorized person of a contract along with a repayment schedule containing personal data of one individual in the form of: first name, last name, PESEL identification number, residential address, bank account number, and series and number of the identity card, which makes it significant and serious, as this event may lead to material or non-material damages for the individual whose data has been breached, and the likelihood of such damages occurring is high.

In connection with the occurrence of a personal data breach, consisting of the disclosure of banking documentation to an unauthorized person, there was an unlawful disclosure of information covered by banking secrecy – which further increases the seriousness of the breach and indicates the possibility of negative consequences of the event for the individuals concerned. The President of the Personal Data Protection Office considers the long duration of the breach by the Bank of Article 33(1) of Regulation 2016/679 as an aggravating circumstance. It should be assumed that it lasted nearly 18 months. The Administrator became aware of the personal data breach on (...) March 2021, while the notification was only made on September 7, 2022, and this was solely due to the ongoing proceedings related to a complaint filed by the Data Subject regarding the disclosure of her personal data to a third party – one of the questions posed to the Administrator in the ongoing proceedings concerned whether, and if so, when, the Bank reported the personal data breach to the supervisory authority. It should also be emphasized that due to the complaint filed by the Bank's Client regarding irregularities in the processing of her personal data by Toyota Bank Polska S.A., consisting of disclosing her personal data to a third party without legal basis, in the opinion of the President of the Personal Data Protection Office, this only confirms that the risk assessment presented in the Bank's explanations in this matter considers only the perspective of the Administrator, which means that it does not take into account the perspective of the Bank's Client, who, as a result of the breach of her personal data, likely suffered non-material damage.

In this case, the breach concerned the personal data of only one individual. Such a number of individuals affected by the breach, especially given the fact that the Bank – due to the scale and scope of its operations – processes the personal data of a very large number of clients, should be considered small, which undoubtedly works in favor of the Administrator; however, this did not change the overall assessment, i.e., the recognition in the analyzed case of the criterion from Article 83(2)(a) of Regulation 2016/679 as aggravating.

2. Intentional nature of the breach (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Bank made a conscious decision not to notify the President of the Personal Data Protection Office of the personal data breach within 72 hours of its discovery. There is no doubt that the Bank, processing personal data on a large scale, must have knowledge in the area of personal data protection, including knowledge of the consequences of identifying a personal data breach resulting in a risk of infringement of the rights or freedoms of individuals (and this knowledge can be required not only from the Administrator but also from the data protection officer appointed by him). Being aware of this, the Administrator nevertheless made the decision to refrain from reporting the personal data breach to the President of the Personal Data Protection Office within

72 hours of its discovery.

3. Relevant previous violations of the provisions of Regulation 2016/679 by the administrator (Article 83(2)(e) of Regulation 2016/679). In making the decision on the imposition and amount of the administrative fine, the supervisory authority is obliged to take into account any previous violations of Regulation 2016/679. EROD in the Guidelines 04/2022[4] on calculating administrative fines based on GDPR adopted on May 24, 2023, explicitly states: "The existence of previous violations can be considered an aggravating factor when calculating the amount of the fine. The weight attributed to this factor should be determined taking into account the nature and frequency of previous violations. The absence of previous violations cannot, however, be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm." And although, as indicated in the aforementioned guidelines, "greater significance should be attributed to violations concerning the same subject matter, as they are closer to the violation that is the subject of the current proceedings, especially when the administrator or processor has previously committed the same violation (repeated violations)" (point 88 of the guidelines), all previous violations can provide information about the overall approach of the administrator or processor to compliance with the regulations. Regulation 2016/679".

The supervisory authority has already established in previously issued administrative decisions that the Administrator has violated the provisions on the protection of personal data: - in the decision dated September 29, 2022 (ref. (...)) a violation of Article 6(1) of Regulation 2016/679; - in the decision dated May 8, 2023 (ref. (...)) a violation of Article 15(1)(c) of Regulation 2016/679; - in the decision dated May 9, 2023 (ref. (...)) a violation of Article 15(1)(a) of Regulation 2016/679; - in the decision dated November 14, 2022 (ref. (...)) a violation of Article 15(1)(c) and Article 12(3) of Regulation 2016/679; - in the decision dated February 1, 2024 (ref. (...)) a violation of Article 6(1) of Regulation 2016/679.

The aforementioned previous violations indicate a generally negligent approach by the Administrator to data protection issues, and the remedial measures previously applied to the Administrator in the aforementioned cases, including twice in May 2023 when the President of the UODO ordered the Bank to adjust its personal data processing operations to the provisions of Regulation 2016/679 due to the violation of Article 15(1)(c) of Regulation 2016/679 and Article 15(1)(a) of Regulation 2016/679, or in connection with decisions issuing warnings to the Administrator for violating Article 6(1) of Regulation 2016/679 as occurred in cases with ref. (...) and (...), fully justify the imposition of a financial sanction in the present proceedings, as well as its amount. It is also significant that the last decision regarding the violation of the provisions of Regulation 2016/679 concerning Toyota Bank Polska S.A., in which the supervisory authority applied a remedial measure (warning) against the Administrator, was issued on February 1, 2024, which, according to Guidelines 04/2022 - "The moment when the previous violation occurred should be taken into account, considering that the longer the time between that violation and the violation currently under investigation, the less significance should be attributed to the earlier violation. Consequently, the older the violation, the less significance supervisory authorities should attribute to it" (point 84 of the guidelines) - should have an impact on the final decision of the supervisory authority and the amount of the imposed administrative fine.

In light of the above, in this case, it should be recognized that there are grounds for treating the criterion from Article 83(2)(e) of Regulation 2016/679 as aggravating.

4. Categories of personal data to which the violation pertained (Article 83(2)(g) of Regulation 2016/679). Personal data disclosed to an unauthorized person do not belong to the special categories of personal data referred to in Article 9 of Regulation 2016/679, nor to the data specified in Article 10 of Regulation 2016/679; however, the fact that the disclosed agreement between the parties contained a wide range of data (name and surname, residential address, PESEL identification number, bank account number, series and number of the identity card) is associated with a high risk of violation of the rights or freedoms of the individual. The PESEL number, which is an eleven-digit numerical symbol that uniquely identifies an individual, containing the date of birth, serial number, gender designation, and control number, is therefore closely related to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation

2016/679, and is data of a special nature requiring such special protection. There is no other, so specific data that would unequivocally identify an individual. It is not without reason that the PESEL number serves as identifying data for every individual and is widely used in dealings with various institutions and in legal transactions. The PESEL number, along with the name and surname, unequivocally identifies an individual, allowing for the attribution of negative consequences of a violation (e.g., identity theft, loan fraud) to that specific individual.

In this context, it is worth recalling the EROD Guidelines 04/2022, which state: "Regarding the requirement to consider the category of personal data to which the violation pertained (Article 83(2)(g) [of Regulation 2016/679]), [Regulation 2016/679] clearly indicates the types of data that are subject to special protection, and thus a more rigorous response when imposing fines. This applies at least to the types of data covered by Articles 9 and 10 [of Regulation 2016/679] and to data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual concerned (e.g., data concerning location, data concerning private communications, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the violation or the more sensitive the data, the greater weight the supervisory authority may attribute to such a factor. The quantity of data concerning each individual whose data is involved is also significant, as with the increase in the amount of data concerning each individual, the scale of the violation of the right to privacy and the protection of personal data increases."

It is also worth noting the developing case law in this area, where, for example, in the judgment dated November 15, 2022, ref. II SA/Wa 546/22, the Provincial Administrative Court in Warsaw stated: "It was also obvious that the authority, when determining the amount of the fine, had to take into account the fact that the violation concerned data of great sensitivity (including PESEL, address, health status data)." This view was also shared by the aforementioned Court in the judgment dated June 21, 2023, in the case ref. II SA/Wa 150/23, where...

****Provincial Administrative Court in Warsaw indicated:****

"Summarizing, the Court is of the opinion that the disclosure of the PESEL number indicates a high risk of violation of the rights or freedoms of natural persons."

In deciding to impose an administrative monetary penalty, the President of the UODO took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which have a mitigating effect on the amount of the imposed administrative monetary penalty:

1. ****Degree of cooperation with the supervisory authority in order to eliminate the violation and mitigate its potential negative effects**** (Article 83(2)(f) of Regulation 2016/679). It should be noted that, apart from properly fulfilling the procedural obligations imposed on the administrator during the administrative proceedings that ended with the issuance of this decision, the Bank cooperated with the supervisory authority during the course of the administrative proceedings by providing relevant information related to the violation of personal data protection (responding to the notification of the initiation of proceedings and the request to submit financial documents necessary to determine the basis for the amount of the administrative monetary penalty). The administrator also reported the violation of personal data protection following the initiation of complaint proceedings and the summons issued in connection with that proceeding, and although this report constituted a specific response to the supervisory authority's request, it is a manifestation of an appropriate reaction to the letters directed to the Bank, and therefore this circumstance should be classified as mitigating.
2. ****Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or losses avoided**** (Article 83(2)(k) of Regulation 2016/679). The Bank notified the data subject of the violation of the protection of their personal data and provided that person with support by purchasing a report from the Credit Information Bureau, which deserves recognition and acceptance; therefore, this action should be considered a mitigating circumstance in this case.

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established violation in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty:

1. ****Actions taken by the administrator to minimize the damage suffered by the data subjects**** (Article 83(2)(c) of Regulation 2016/679). Despite the Administrator notifying the data subject of the violation of the protection of their personal data, resulting from Article 34(1) of Regulation 2016/679, in which notification the Administrator indicated to that person measures to potentially prevent possible negative consequences of the violation, due to the nature of the violation established in this case (failure to notify the President of the UODO of the violation of personal data protection without undue delay, no later than within 72 hours of its discovery) - which violation does not directly relate to the risk of damage to the person affected by the violation of personal data protection - it should be accepted that the condition indicated in Article 83(2)(c) of Regulation 2016/679 does not have an impact, either aggravating or mitigating, on the amount of the imposed administrative monetary penalty. It is not significant in assessing the Bank's violation of Article 33(1) of Regulation 2016/679.

2. ****Degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him pursuant to Articles 25 and 32**** (Article 83(2)(d) of Regulation 2016/679). Due to the nature of the violation established in this case (failure to notify the President of the UODO of the violation of personal data protection without undue delay, no later than within 72 hours of its discovery) - which violation does not relate to the technical and organizational measures applied by the administrator - it should be accepted that the condition indicated in Article 83(2)(d) of Regulation 2016/679 does not have an impact, either aggravating or mitigating, on the amount of the imposed administrative monetary penalty. It is not significant in assessing the Bank's violation of Article 33(1) of Regulation 2016/679.

3. ****The manner in which the supervisory authority became aware of the violation**** (Article 83(2)(h) of Regulation 2016/679). The President of the UODO was informed of the occurrence of the violation of Article 33(1) of Regulation 2016/679 related to the event of the Administrator providing a document containing personal data to an unauthorized recipient, as a result of the notification of the violation of personal data protection made by the Bank almost 18 months after its discovery. Moreover, the notification of the violation after such a significant time was related to the ongoing parallel proceedings before the President of the UODO initiated by the complaint of the person affected by the violation, in which the President of the UODO had inquired of the Bank, among other things, about making the notification of the violation. It was established that only the above-mentioned summons led to the notification of the violation of personal data protection.

The failure to notify the supervisory authority of the violation of personal data protection without undue delay, no later than within 72 hours of the discovery of the violation, is the sole subject of these proceedings, and in the circumstances of the considered factual state, the supervisory authority accepted that the conditions...

****4.**** The adherence to previously applied measures in the same case, as referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures against the Administrator in the case under consideration, as a result of which the Administrator was not obliged to take any actions related to their application, which actions, when assessed by the President of the UODO, could have had a burdensome or mitigating effect on the assessment of the established violation.

****5.**** The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Administrator does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as stipulated by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered detrimental to the Administrator in this case. Conversely, the circumstance of adopting and applying such instruments as

measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

****6.**** Financial benefits obtained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the Administrator had obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds for treating this circumstance as burdensome for the Administrator. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 would need to be assessed very negatively. On the other hand, the absence of such benefits for the Administrator, as a natural state independent of the violation and its effects, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" - which occurred on the part of the entity committing the violation.

The President of the UODO, having comprehensively considered the matter at hand, did not record any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty.

In the opinion of the President of the UODO, the applied administrative monetary penalty fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

It should be emphasized that the penalty will be effective if its imposition leads to the Bank, which processes personal data professionally and on a large scale, fulfilling its obligations regarding the protection of personal data in the future, particularly in terms of reporting personal data breaches to the President of the UODO.

In the opinion of the President of the UODO, the administrative monetary penalty will serve a repressive function, as it will constitute a response to the Bank's violation of the provisions of Regulation 2016/679. It will also fulfill a preventive function; in the opinion of the President of the UODO, it will indicate to both the Bank and other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of personal data breaches, which are aimed at preventing their negative and often severe consequences for the individuals affected by the breach, as well as removing those consequences or at least limiting them.

Pursuant to Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo," the equivalent amounts expressed in euros, referred to in Article 83 of Regulation 2016/679, are calculated in zloty according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Having the above in mind, the President of the UODO, based on Article 83(4)(a) in connection with Article 103 of uodo, for the violation described in the operative part of this decision, imposed on the Bank - using the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) - an administrative monetary penalty in the amount of 78,575.40 PLN (which is equivalent to 18,000 EUR).

In the opinion of the President of the UODO, the imposed monetary penalty of 78,575.40 PLN (in words: seventy-eight thousand five hundred seventy-five zlotys and forty groszy) meets the criteria referred to in Article 83(1) of Regulation 2016/679 due to the severity of the established violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, particularly the right to the protection of personal data. Referring to the amount of the administrative monetary penalty imposed on the Bank, the President of the UODO considered it to be proportional to the financial situation of the Administrator and that it would not constitute an excessive burden for him. The financial report presented by the Administrator shows that

the total revenue of the Bank for the financial year ending on March 31, 2023, amounted to 319,617,075 PLN, which means that the amount imposed...

In this administrative matter regarding the monetary penalty, the amount constitutes approximately 0.02% of the aforementioned revenue. At the same time, it is worth emphasizing that the imposed penalty amount of 78,575.40 PLN is merely about 0.18% of the maximum penalty that the President of the UODO could have imposed on the Bank for the violation identified in this case, applying the static maximum penalty in accordance with Article 83(4) of Regulation 2016/679 (i.e., 10,000,000 euros).

The amount of the penalty has been set at such a level that, on one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, it does not lead to a situation where the necessity to pay the financial penalty results in negative consequences, such as significant job reductions or a substantial decrease in the Bank's turnover. According to the President of the UODO, the Bank should and is capable of bearing the consequences of its negligence in the area of data protection, as evidenced by the Bank's financial report submitted to the President of the UODO on December 15, 2023.

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022 on calculating administrative monetary penalties under the GDPR, adopted on May 24, 2023. According to the guidance presented in this document:

The President of the UODO categorized the violation of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of Guidelines 04/2022). The violation of Article 33(1) of Regulation 2016/679 identified in this case falls—according to Article 83(4)(a) of Regulation 2016/679—into the category of violations subject to a lower penalty among the two dimensions of penalties provided for in Regulation 2016/679 (with a maximum amount of up to 10,000,000 EUR or up to 2% of the total annual turnover of the enterprise from the previous financial year). Thus, it has been considered in abstracto (independently of the individual circumstances of the specific case) by the EU legislator as less serious than the violations indicated in Article 83(5) of Regulation 2016/679.

The President of the UODO assessed the violation identified in this case as a violation of low severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria among those listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violation (constituting the "seriousness" of the violation) were taken into account, namely: the nature, gravity, and duration of the violation (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679).

A detailed assessment of these circumstances has been presented above. It should be noted here that considering their combined impact on the assessment of the violation identified in this case treated in its entirety leads to the conclusion that the level of its seriousness is also low in concreto (on the scale of seriousness of violations presented in point 60 of Guidelines 04/2022). Consequently, this results in the acceptance—as the starting amount for calculating the penalty—of a value falling within the range of 0 to 10% of the maximum penalty that could be imposed on the Bank.

Considering that Article 83(4) of Regulation 2016/679 obliges the President of the UODO to adopt, as the maximum penalty for the violation indicated in this provision, the amount of 10,000,000 EUR or—if this amount is higher than 10,000,000 EUR—the amount representing 2% of the Bank's turnover from the previous financial year, the President of the UODO states that the so-called static maximum penalty amount of 10,000,000 EUR applies in this case. The application of the 2% rate applied to the Bank's turnover for the financial year ending March 31, 2023 (73,217,665 EUR, which is equivalent to 319,617,075 PLN according to the average EUR exchange rate on January 29, 2024) results in an amount of 1,464,353 EUR—lower than the static maximum penalty referred to in Article 83(4) of Regulation 2016/679. Therefore, having at his disposal a range from 0 to 10,000,000 EUR, the President of the UODO accepted, as adequate and justified by the circumstances of the case, a starting amount for calculating the penalty of 300,000 EUR (constituting 3% of the static maximum

penalty).

The President of the UODO adjusted the starting amount corresponding to the low severity of the identified violation to the Bank's turnover as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises with an annual turnover between 50 and 100 million EUR, the supervisory authority may consider making further calculations of the penalty amount based on a value falling within the range of 8% to 20% of the starting amount. Given that the Bank's turnover in the last reporting year (ending March 31, 2023) amounted to 319,617,075 PLN, which is 73,217,665 EUR (according to the average EUR exchange rate on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 12% of the starting amount, that is, to the amount of 36,000 EUR (equivalent to 157,150.80 PLN).

The President of the UODO assessed the impact of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating impact on the assessment of the violation, relate—as assumed by Guidelines 04/2022—to its subjective aspect, that is, to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these criteria on...

The assessment of the violation has been presented above. The President of the Personal Data Protection Office (UODO) recognized that the mitigating circumstances in this case are: the degree of cooperation of the Bank with the supervisory authority in order to rectify the violation and mitigate its negative effects (Article 83(2)(f) of Regulation 2016/679), as well as the actions taken by the Bank towards the individual whose data became the subject of the data protection violation ("other mitigating factors" referred to in Article 83(2)(f) of Regulation 2016/679).

On the other hand, the relevant previous violations of the Bank in the area of personal data protection identified by the President of UODO have an aggravating effect on the penalty (Article 83(2)(e) of Regulation 2016/679). The remaining criteria (from Article 83(2)(c), (d), (h), (i), (j) of Regulation 2016/679) – as indicated above – did not have either a mitigating or aggravating effect on the assessment of the violation and consequently on the penalty. Due to the existence of the aforementioned mitigating and aggravating circumstances in the case, the President of UODO deemed it appropriate to further reduce the amount of the penalty determined above, taking into account the turnover of the Bank (point 3 above); in the opinion of the President of UODO, the appropriate reduction of the assessed overall impact of the aforementioned criteria on the assessment of the violation is to reduce it to the amount of 28,800 EUR (equivalent to 125,720.64 PLN).

Finally, the President of UODO assessed the amount of the penalty determined in the manner specified above in the context of the principles of effectiveness, proportionality, and deterrent nature of the administrative monetary penalty (see Chapter 7 of Guidelines 04/2022). As a result of this assessment, the President of UODO concluded that it requires additional adjustment due to the proportionality directive indicated by the EU legislator – as one of the three fundamental principles – in Article 83(1) of Regulation 2016/679. A monetary penalty of 28,800 EUR would, in the opinion of the President of UODO, undoubtedly be an effective penalty (due to its clear severity, it would achieve its repressive goal, which is to punish unlawful behavior) and deterrent (effectively discouraging both the Company and other administrators from committing violations of the provisions of Regulation 2016/679 in the future).

However, such a penalty would be – in the opinion of the President of UODO – disproportionately high in relation to the seriousness of the established violation (which, both in abstracto and in concreto, is low – see points 1 and 2 above) and in the context of assessing the Bank's conduct after the violation was established, which – as indicated above in the assessment of the criteria from Article 83(2)(f) and (k) of Regulation 2016 – should generally be assessed positively. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of

Guidelines 04/2022). In other words: “A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case” (P. Litwiński (ed.), Regulation of the European Parliament and Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected Sectoral Provisions. Commentary).

Therefore, taking into account the proportionality of the penalty, the President of UODO made a further reduction – to the amount of 18,000 EUR (equivalent to 78,575.40 PLN). In his opinion, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the amount of the penalty will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the penalty could occur at the expense of its effectiveness and deterrent nature, as well as a consistent understanding, application, and enforcement of Regulation 2016/679 in relation to other supervisory authorities and the EDPB, as well as the principle of equal treatment of entities in the EU and EEA internal market.

Importantly, the effectiveness and deterrent nature of the penalty imposed in this case (even at an amount far from its maximum limit) will consist in the fact that the fact of its imposition will undoubtedly have an aggravating impact on the assessment of any subsequent violations of the provisions of Regulation 2016/679 committed by the Bank in the future.

In this factual and legal state, the President of the Personal Data Protection Office ruled as stated in the operative part.

[1] Guidelines of the European Data Protection Board on reporting personal data breaches, version 2.0, hereinafter referred to as Guidelines 9/2022. The aforementioned guidelines updated and supplemented the Guidelines of the Article 29 Working Party on reporting personal data breaches in accordance with Regulation 2016/679 (Wp250 rev.01), adopted on October 3, 2017.

[2] Guidelines of the European Data Protection Board 01/2021 on examples regarding notification of personal data breaches adopted on December 14, 2021, version 2.0, hereinafter referred to as “Guidelines 01/2021”.

[3] Report on the activities of the President of the Personal Data Protection Office in 2021, p. 181.

[4] Guidelines 04/2022 on calculating administrative fines under the GDPR adopted on May 24, 2023, version 2.1, hereinafter referred to as “Guidelines 04/2022” (available in English at: https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-und_er_pl)

Print article

Metadata

Provider: Department of Control and Violations

Information created by: Mirosław Wróblewski

2024-03-12

Information entered by: Wioletta Golańska

2024-03-28 09:11:41

Last modified by: Edyta Madziar

2024-04-02 10:06:22